

[doc. web n. 10134827]

Provision of April 29, 2025

Register of provisions

n. 271 of April 29, 2025

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by

Prof. Pasquale Stanzione, President, Prof.

Ginevra Cerrina Feroni, Vice President, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Dr. Claudio Filippi - the acting Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament

and of the Council of April 27, 2016, concerning

the protection of natural persons with regard to

the processing of personal data, as well as the free

movement of such data and repealing Directive

95/46/EC, "General Data Protection Regulation" (hereinafter, "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing

"Code regarding the protection of personal data,

containing provisions for the adaptation

of the national legal system to Regulation (EU)

2016/679 of the European Parliament and of the Council, of

April 27, 2016, concerning the protection of

natural persons with regard to the processing of personal data,

as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter

"Code");

HAVING REGARD to Regulation No. 1/2019 concerning

internal procedures with external relevance,

aimed at carrying out the tasks and

exercising the powers entrusted to the Guarantor for the

protection of personal data, approved by

resolution No. 98 of April 4, 2019, published in

G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc.

web n. 9107633 (hereinafter "Guarantor Regulation

No. 1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary General

pursuant to Article 15 of Guarantor Regulation No. 1/2000 on the

organization and functioning of the office of the Guarantor for the

protection of personal data, doc. web n. 1098801;

Rapporteur Attorney Guido Scorza;

PREMISED

1. Introduction.

On October 19, 2023, the Order of Psychologists

of the Lombardy Region (hereinafter, the "Order") notified the Authority, pursuant to Article 33 of the

Regulation, of a personal data breach,

which occurred on October 3, 2023, concerning an "unauthorized

access to the computer network, data encryption on

servers, and deletion of data from backup NAS" (see

notification of October 19, section F, point 8).

Subsequently, on November 20, 2023, the Order

supplemented the aforementioned notification, stating that

it had been the victim of "a sophisticated ransomware

attack by the criminal association NoEscape [which]

resulted in unauthorized access to the Order's computer network, data encryption, and subsequent deletion of backups that were, however, recovered later [...] on October 10, 2023, when the Data Controller became aware of the "malicious" source of the anomalies detected in the previous days, [...] following the receipt of an email from csirt@pec.acn.gov.it indicating a reference to a link on Onion that led to a page threatening the publication of 7GB of data [...]. Subsequently, following the failure to pay the ransom, the cybercriminals on October 18 and October 31, 2023, published the exfiltrated data on the dark web."

The Order stated that it could "exclude the loss of integrity and availability of the data [since] all archives have been completely restored thanks to backups executed in the cloud of [a provider] and the presence of backups on external USB drives stored in a safe. Furthermore, [...] the malicious agent was able to encrypt and exfiltrate only 6.9GB (including 4.5 GB): this amount is only a small fraction compared to the overall size and volume of data contained in the Order's archives, which corresponds to hundreds of GB, which were not impacted. In fact, only some folders containing files were impacted, not all of them. [...] The Data Controller also has no evidence that other data, different from those published on the dark web, were accessed by the cybercriminals, and they have always referred only to the data subsequently published on the dark web" (see notification of November 20, sections F, point 7 and G, point 1.4).

The Order also represented that the individuals involved in the cyber attack were 3,000 and that the "impact of the breach [...] is high with exclusive reference to the data of [individuals involved in] [...] disciplinary proceedings and the persons mentioned in those proceedings, which represent only a very limited part of the breached data" - quantifying such proceedings at 159, "of which most concern the last two years" - while "for other older proceedings, the documentation concerns only the parties involved and the adopted measure." The Order, however, deemed "in relation to the employees and the only three collaborators of the Data Controller whose identity documents were exfiltrated, [...] that the severity [was] medium" (see notification of November 20, 2023, sections F, point 13, and G, point 3).

From the documentation on file, it emerges that the breach involved approximately 15,000 records of personal data, including personal, contact, payment data, related to identity/recognition documents, covered by professional secrecy, as well as data belonging to special categories

(cf. Article 9 of the Regulation and Article 2-sexies of the Code),

****Data revealing racial or ethnic origin, religious or philosophical beliefs, trade union membership, sexual life or sexual orientation, health status, as well as data relating to criminal convictions and offenses (cf. art. 10 of the Regulation and 2-octies of the Code). This has resulted in the affected individuals being exposed, as assessed by the Order and stated in the notifications of the violation, to risks of loss of data control, discrimination, identity theft, fraud, damage to reputation, knowledge by unauthorized third parties, and significant economic and social harm.****

****With reference to the measures in place at the time of the violation, the Order stated that it was conducting "constant checks on the updates of the operating systems of server and client workstations, the firmware of network devices [and that it adopted a] correctly configured and monitored authentication system, antivirus [...] on all workstations, local backups on two NAS located at the two sites, a cloud backup [...] five USB HDs in a safe at the headquarters [...] and two USB HDs kept in a safe deposit box at the bank of the institution" (see notification of October 19, 2023, section F, point 9). Furthermore, the Order "had adopted the following measures: (i) firmware of network devices, (ii) correctly configured and monitored authentication system, (iii) endpoint antivirus reset on all workstations, (iv) local backups on two NAS located at the two sites, (v) a cloud backup with [a third-party provider], (vi) five USB HDs in a safe at the headquarters of the Data Controller and two USB HDs kept in a safe deposit box at the bank of the institution [...]; a VPN (Virtual Private Network) for connection to the systems of the Order. All these measures were constantly monitored and updated." The Order detailed these measures in a note dated January 19, 2024 (pages 2 – 4).****

****Regarding the measures adopted following the violation, the Order represented that "it activated to better understand what happened and recover the backup copies (physical and cloud) of the data residing on its servers [, having] promptly involved in the recovery activities [a third-party provider] [...] and proceeded to (i) disable on the firewall all rules that allowed external access to terminal server XX which contains the software of the Psychologists' Register, (ii) block all active VPNs and add rules that blocked all traffic to and from the network from 9:00 PM to 7:00 AM, (iii) change the password starting from the domain server and then to the ESX servers that contain the virtual machines. In the meantime, [it had] already created a new virtual machine on which [a] backup software was installed [...]. Once the operation was completed, the virtual server that acts as Domain Controller was restored, using a backup copy present on a physical disk locked in a safe with a backup date of July 31, 2023. Thanks to some cloud backups with [a third-party provider] and some physical backup disks in a safe and in the safe deposit box at the Order's reference bank, the Data Controller was able to restore the data by recovering the deleted data thanks to the cloud and physical backups, bringing the situation back to the day before the attack. Therefore, the loss of availability and integrity of the data was only temporary thanks to the completed recovery activities. Furthermore, [...] tests were then conducted to understand the anomalies encountered and the nature of the event [, installing] a specific monitoring software on all machines, including its own servers. Subsequently, [it proceeded to] 1. successfully restore the data, also allowing the use of cloud applications; 2. restore server XX, that is, the file server of the Data Controller; 3. realign the PCs of users not present in the previous days, recover the NAS backups present on site, change the passwords of new users; 4. after obtaining confirmation [from the third-party provider] that, once all data had been copied, the Data Controller could proceed with the deletion of the encrypted files, (i) delete the encrypted files from the server at the Psychology House after copying to NAS, and (ii) begin the creation of a new virtual machine on the ESX server of the Psychology House. When the data was published on the dark web, the Data Controller conducted online verification activities, including on the dark web, trying to identify any presence of data related to the archives subject to encryption and deletion and to reconstruct the impacted personal data" (see notification of November 20, 2023, section H, point 1).****

****In relation to the technical and organizational measures adopted to prevent similar violations in the future, the Order stated that "after restoring the data and deleting the encrypted copies [...] it implemented measures such as: (i) the creation of VPN access with certificates instead of the old local users, (ii) conducting functionality tests, and (iii) modifying the connection rules of VPN users on the**

Order's network, limiting access to only the necessary servers. Furthermore, the new backup agent [...] was installed on server XX and the backup was reconfigured both on the cloud [...] and on the 4 NAS [...]. The Order is proceeding with the adoption of a new cloud application for the management of the register of members of the order and is evaluating the purchase of an application that, in addition to collecting log files, also performs analysis functions and provides alerts to the ADS [...]. The IT representatives of the Data Controller have restored all archives and are preparing a plan to optimize the appropriate measures that were already in place.**

being at the IT structure of the order by adopting stricter measures regarding special categories of data such as the adoption of a multi-factor authentication (MFA) system and the encryption of archives. The adoption of monitoring software is under evaluation to identify potential critical situations and alert the ADS, as well as a solution that ensures the integrity of on-site backups and a rapid data recovery, in addition to the measures already adopted (see notification of November 20, 2023, section H, point 2).

Regarding the communication of the breach to the affected individuals, the Order, in the supplementary notification, stated that it would make communications to the affected individuals "by November 24, 2023 [...] for the reporters/reported and individuals mentioned in the proceedings" and that it would make such communications "also for the benefit of the employees and the 3 aforementioned collaborators as a precaution." In particular, the Order expressed its intention to send "an email communication regarding the reporters and reported individuals related to the proceedings from 2018 to the present that can be reasonably traced" and stated that "the breach will be communicated directly to 334 affected individuals (a number that includes the traceable subjects involved in the disciplinary proceedings, 13 employees, and 3 suppliers)," while "regarding the other affected individuals, the Data Controller will publish a public communication on its website as, in accordance with Article 34, paragraph 3, of the Regulation, sending a communication to the affected individual would require disproportionate efforts." In this regard, three types of communications were produced: "1. Individual communication for the reporters and reported individuals of the disciplinary proceedings who are identifiable; 2. Communication published on the website regarding individuals to whom a communication cannot be sent; 3. Individual communication for the employees and the 3 collaborators whose identity documents were exfiltrated" (see notification of November 20, 2023, section L, points 3 and 4).

The Order finally stated that it had communicated to the affected individuals the occurrence of the personal data breach, pursuant to Article 34 of the Regulation, "on November 23, 2023 – to the individuals who presented a high level of risk concerning the Incident, i.e., the reported and reporters within the disciplinary proceedings as well as the employees of the Order" (see note of January 19, 2024, p. 11), through an individual communication, and "regarding the other affected individuals [through] a public communication on its website as, in accordance with Article 34, paragraph 3, of the Regulation, sending a communication to the affected individual would require disproportionate efforts" (see notification of November 20, 2023, section L, point 3).

In relation to the personal data breach in question, two complaints were submitted to the Guarantor pursuant to Article 77 of the Regulation and a report pursuant to Article 144 of the Code.

2. The investigative activity.

In response to a request for information from the Authority (note prot. n. 0168453/23 of December 21, 2023), the Order, with note of January 19, 2024 (prot. 0001441), supplemented the information regarding the technical and organizational measures implemented to prevent similar breaches in the future, stating that it had "adopted a plan," which includes the installation of a "software tool for detecting threats to data security [...]; a) new network segmentation [to] strengthen its protection against cyber attacks, isolate potential attacks, and prevent them from spreading across the network and infecting other servers and devices [...]; new backup procedures and air-gap between production and backup," highlighting "the reliability of the 'multi-level' data backup system" in place at the time of the breach (see note of January 19, 2024, pp. 4 - 5).

Following a further request for information from the Authority (note prot. n. 0067836/24 of June 4,

2024), the Order, with note of June 19, 2024 (prot. 0009014), provided a copy of an analysis conducted by an external consultant, which revealed that "the NoEscape group published on their leak site a 7zip archive divided into three parts [...] [and that] the size of the 5 published data amounts to 4.16GB and contains: Identity cards and passports; Confidential agreements; Contracts; Banking documents; Data related to their clients; Internal reports" (see Incident Response Report (IR) - v.1.1, attached to the note of June 19, 2024, p. 20 – hereinafter "incident report").

With note of October 16, 2024 (prot. n. 0120794), the Office, based on the elements acquired, the checks carried out, and the facts emerged following the investigative activity, notified the Order, pursuant to Article 166, paragraph 5, of the Code, of the initiation of the procedure for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation, for having failed to adopt adequate measures to promptly detect personal data breaches and ensure their security, in violation of Articles 5, paragraph 1, letter f), and 32, paragraph 1, of the Regulation. With the same note, the aforementioned data controller was invited to submit defensive writings or documents to the Guarantor or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code, as well as Article 18, paragraph 1, of Law No. 689 of November 24, 1981).

With note of November 15, 2024, the Order, through its lawyers, submitted a defensive memorandum, stating, in particular, that: - "the Order - despite significant economic restrictions [...] - has implemented its security measures in accordance with the guidelines of the Agency for Digital Italy ("AgID") of to the Circular No. 2/2017 of April 18, 2017 [...] regarding the "minimum ICT security measures for public administrations" [...] [, provided that] the Order periodically updates these measures in order to ensure an adequate level of cybersecurity in line with the progressive technological development";

- "the combined provisions of Articles 5, paragraph 1, letter f) and 32, paragraph 1, of the Regulation provide [...] not [provide] a numerus clausus of measures that must be mandatorily adopted [...]. On the contrary, the implementation of specific security measures depends on the level of risk posed by the specific processing, as well as on the technological evolution of the sector and the costs of implementation and the resources actually available for their implementation";

- "in the case of public administrations, however, an indication of the expected security measures is provided by the AgID Circular which foresees the following three levels of security: "minimum" [...]; "standard", which can be taken as a reference basis for most public administrations; "high" [...];

- "the Order, as a non-economic public entity – and thus a public administration under the provisions of Legislative Decree 165/2001 subject to the competence of AgID – has adopted its own security measures in line with the provisions of the AgID Circular, conforming to the standard level referred to in letter b) [...];

- "this level of security is to be considered adequate given the actual level of risk for the Order's systems in light of the following circumstances: a) the activities carried out by the Order do not fall within the definition of essential services for citizens as per the AgID Circular; b) from an organizational perspective, the Order does not fall among the public administrations that, due to size and economic capacity, present a high level of risk";

- "[...] the Order is a non-economic public entity with limited self-sustaining capacity with only 13 employees. The Order does not receive state subsidies and its economic resources derive solely from payments made by its members. Nevertheless, [...] the Order has always paid particular attention to the issue of cybersecurity, allocating on average 5-7% of its annual revenue to the management of its resources and technological infrastructures [...] in line with market standards [...];

- "therefore, the adoption of higher-level measures would have imposed a disproportionate burden on the Order [...];

- "with regard to the failure to adopt an appropriate so-called alert mechanism for the timely identification of any anomalies in the Order's systems, it is specified [...] [that...] the Order had already implemented [a] firewall [...] to protect its corporate perimeter, which is capable of detecting logs and RDP (Remote Desktop Protocol) connection attempts from the outside, including any attempts of

unauthorized access to the corporate network. In particular, the logs collected by the firewall were stored on the Order's infrastructure servers and sent to a storage mechanism [...] in order to have a double copy of the logs. The monitoring of such logs, moreover, was entrusted to the Order's employees, who periodically monitored the firewall logs to identify any suspicious access”;

- “such measures were, therefore, overall suitable for promptly identifying a data breach for two main reasons [...], being] in line with the AgID Circular which, for the timely identification of breaches, considers the adoption of – inter alia – measures that provide for the recording of any anomaly compared to normal network traffic to allow for offline analysis sufficient. In fact, according to AgID, the adoption of DLP (Data Loss Prevention) mechanisms capable of autonomously identifying suspicious situations and sending an alert is to be considered a high-level measure to which the Order is not required to conform. Furthermore, the adoption of a so-called alert and log monitoring mechanism that is more advanced would have required an investment, in terms of economic and labor resources, disproportionate for the Order”;

- “[...] to ensure constant monitoring of detected alerts, the Order would also need to have sufficiently qualified personnel to carry out this activity, even on weekends and at night”;

- “in any case, [...] as soon as the Data Breach occurred, the Order initiated a process aimed at increasing the level of security of its systems within the limits of the economic resources available to it. In particular: [...] [a] software was installed [...] that allows receiving alerts upon changes in Active Directory configurations or in case of access to systems with particular user accounts”;

- “[...] due to the characteristics and modalities of the attack [...], the mechanism itself would not have been effective in preventing the occurrence of the breach [...] and/or in ensuring a more timely identification. The prerequisite for the alert mechanism in question to function is that attackers generate anomalous traffic due to the volume, geographic origin, or time period of the accesses. Where such anomalous traffic is absent, the alert mechanism would therefore not be able to identify suspicious situations”;

- “[...] the attack suffered by the Order [is] of the brute force type (i.e., the attackers repeatedly attempted to access the Order's IT resources using the login credentials of some users) [...]”;

- “[...] no "traffic spikes" were recorded. exposed to potential threats”;

- “the Order has also implemented a new procedure for incident response that includes: (i) immediate notification to affected parties; (ii) thorough investigation of the breach; and (iii) measures to prevent future occurrences”;

- “in conclusion, the Order has taken all necessary steps to ensure the security of its systems and to comply with the requirements set forth by the AgID Circular. The measures in place were adequate at the time of the incident and have since been enhanced to further strengthen the security posture of the organization.”

reachable from the LAN network without activating firewall rules (only if necessary)”;

- regarding the contested "lack of protection of credentials with state-of-the-art cryptographic algorithms [...] it is [...] essential to clarify that: (i) the email domain “opl.it” and the Active Directory domain used for access to the internal servers of the Order reside on different servers: the former on external servers of the Order (opl.it), while the latter on the internal servers of the Order (opl.lan); (ii) the analysis conducted only concerned what was present on the dark web and identified vulnerabilities only in the external domain of the Order (opl.it); and (iii) the analyzed credentials refer exclusively to the email domain and do not allow access to the internal systems of the Order in any way”;

- therefore, “it is completely irrelevant that some of the aforementioned credentials were classified with severity “critical” and “high”, since they belonged to email addresses that could not be used to access the internal systems of the Order. Moreover, only 3 out of 12 users were found to be employees of the Order, and none of these had a password classified as “critical” or “high”. Many of the exposed credentials were, in fact, outdated or fabricated [...]. Consequently, the alleged lack of encryption of

such credentials is entirely disconnected from the dynamics of the attack";

- "[...] the credentials used to access the internal systems of the Order were protected by state-of-the-art cryptographic algorithms. In fact, access to the servers occurred via Active Directory, which by default uses encryption. Finally, in order to introduce an additional layer of protection, the disks of the users' computers were encrypted, requiring an additional initial password for access. Such encryption measures are in line with the AgID Circular, which provides for the obligation "to conduct a data analysis to identify those with particular confidentiality requirements (relevant data) and specifically those to which cryptographic protection must be applied";

- "it is appropriate to observe the irrelevance of the reference made by this Authority to the Guidelines on Cryptographic Functions – Password Storage adopted by provision no. 594 of December 7, 2023 [doc. web no. 9962283], as they had not yet been adopted at the time the contested events occurred";

- "the Order is evaluating the adoption of a cryptographic system in line with the requirements set forth by the Authority, as well as by EU Directive 2022/2555";

- "the contested conduct [...] (i) concerned a small number of affected individuals and personal data compared to those present in the Order's system (6.9 GB out of a total of 350 GB); (ii) generated a high risk to a limited number of affected individuals [...] [and] the Order notified the individuals impacted by a higher risk on an individual basis, while for others it published a freely accessible announcement on its website; (iii) resulted only in a loss of confidentiality, without affecting the integrity and availability of the data, whose compromise was only temporary thanks to the actions taken by the Order to limit the negative effects and the presence of information backups; (iv) did not significantly impact the Order's systems [...];

- "in order to improve the detection of violations and the security of systems, as well as to prevent similar attacks in the future, the Order has taken steps to: (i) create certified VPN access; (ii) adopt a multi-factor authentication (MFA) system; (iii) define stricter password policies; (iv) block nighttime access to the network; (v) deactivate all server entries and implement stricter access rules; (vi) monitor the geolocation of external access; (vii) introduce further network segmentation [...] to isolate potential new attacks and prevent them from spreading across the network and infecting other servers and devices; (viii) reconfigure existing network switches [...]; (ix) limit remote access via VPN [...]; (x) implement new immutable backup systems [...]; (xi) implement an air-gap between the production environment and backup [...] (xiii) modify the VPN user connection rules, encrypt archives, and adopt a new cloud application for managing the Register";

- "[...] the severity of the impact of the violation [...] is high with exclusive reference to the subjects related to the disciplinary proceedings exfiltrated and the persons mentioned in those proceedings, which represent only a very limited part of the data obtained unlawfully (i.e. 159 proceedings).

Regarding the personal data of employees involved in the Data Breach, however, the only special categories of personal data affected relate to the union membership of those employees due to the presence solely of payment receipts for membership fees. Finally, regarding the other categories of affected individuals involved, particularly suppliers and other members of the Order not involved in disciplinary proceedings, the information subject to the personal data violation is predominantly in the public domain. In general, therefore, the Data Breach did not involve the most sensitive data processed by the Order."

During the hearing, requested pursuant to Article 166, paragraph 6, of the Code and held on December 2, 2024 (see protocol no. 0141629 of the same date), the Order, represented by its lawyers, stated, in particular, that:

- "the attack [...] was particularly sophisticated and elusive and, therefore, even adopting more advanced alert systems would not have been possible."

to address the specific reserve expressed during the hearing, the Order, also through its lawyers, declared in a note dated December 11, 2024, in particular, that:

- although in its defense memorandum the Order stated that "the access by cybercriminals to the IT systems did not occur through the theft of access credentials, but rather due to a bug in the system that was promptly resolved by the Order [...], it is appropriate to clarify that, from a purely technical-informatic perspective, the term 'bug' was used in the memorandum to refer to a 'vulnerability' in the systems that the cybercriminals exploited to gain illegitimate and easy access";

- “specifically, the compromised vector used by the attackers appears to be 'the server XX' – which exposed the Remote Desktop Protocol ('RDP') service – from which external connections were recorded throughout the attack (i.e., from September 30, 2023, to October 3, 2023), with scans to detect the presence of any vulnerabilities. However, the initial connection requests were recorded as failed attempts to access the RDP. Access actually occurred in the final phase of the attack (i.e., from 23:12 on October 2, 2023, to 04:01 on October 3, 2023)”;
- “the RDP system is a system that allows remote access to a computer or server running on the same local area network (LAN), enabling authorized users to view the screen and interact with the system as if they were physically present. However, to enable such remote connections, RDP requires the opening of open and publicly visible ports. This characteristic exposes RDP to external access by unauthorized individuals”;
- “in this specific case, from what emerges from the Incident Response Report [...], it must be considered that the attackers: (i) identified the vulnerability of the server exposing the RDP service through active scans by automated agents or bots; and (ii) attempted to access the system by exploiting credentials presumably obtained from the dark web or through other automated tools used to make repeated access attempts that generate random combinations of usernames and passwords until a valid one is found (so-called brute force attack)”;
- “in any case, it is to be excluded that the origin of the personal data breach can be traced exclusively to the exposed credentials related to the domain 'opl.it' [...] since the stolen credentials refer solely to the email domain and did not allow any access to the Order's RDP system (which, instead, is the system that the cybercriminals actually accessed)”;
- “the email domain 'opl.it' and the Active Directory domain used for access to the Order's internal servers reside on different servers [...]; (ii) the analysis conducted revealed vulnerabilities only in the Order's external domain (opl.it); and (iii) the credentials used are email addresses that, in some cases, are not even associated with a valid account. In fact, only 3 out of 12 addresses are attributable to employees of the Order, while many of the exposed credentials were found to be outdated or fabricated [...], and in any case not usable for access to the RDP, which is the system that the attackers actually accessed”;
- “the analyses conducted on the elements and logs provided by the technical contact of the organization allowed for the identification of the probable entry vector, specifically a server that exposed the Remote Desktop service”;
- “in light of the above, access to the Order's IT systems occurred due to a vulnerability of an RDP access point in the Order's infrastructure, although the attackers attempted to use credentials that were likely already in their possession (presumably via the dark web) or generated through a brute force attack”;
- “however, the stolen credentials did not allow access to the Order's network (i.e., to the exposed RDP system). Therefore, even if the Order had adopted multi-factor authentication solutions, this would not have prevented the occurrence of the personal data breach”;
- “in any case, the economic conditions of the Order

****3. Outcome of the Investigative Activity.****

****3.1 The Regulations on Personal Data Protection.****

Pursuant to Article 5, paragraph 1, letter f), of the Regulation, the processing of personal data must be carried out in accordance with the principle of "integrity and confidentiality," according to which personal data must be processed in a manner that ensures adequate security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through appropriate technical and organizational measures.

Based on this principle, Article 32 of the Regulation provides that the data controller, taking into account the state of the art and the costs of implementation, as well as the nature, subject matter, context, and purposes of the processing, and the risk of varying likelihood and severity for the rights and freedoms of natural persons, must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk. The controller is the entity responsible for implementing such measures and must be able to demonstrate that the processing is carried out in

accordance with the Regulation (see Articles 5, paragraph 2, and 24 of the Regulation; cf. the "Guidelines 07/2020 on the concepts of data controller and data processor under the GDPR," adopted by the European Data Protection Board on July 7, 2021, specifically point 41).

****3.2 The Failure to Adopt Adequate Measures to Detect Personal Data Breaches.****

As evidenced by the documentation on file, from the "preliminary analyses of the logs of the FireWall [...] installed to protect the corporate perimeter, [the following was detected]: during the period between September 30 and October 1, 2023, numerous attempts to connect via RDP (Remote Desktop Protocol) from outside were directed at the machines 'XX' and 'XX' [...] [and that] from October 2, RDP sessions were recorded in the evening hours lasting until October 3, suggesting, therefore, a persistent threat [...] it is [therefore] likely that the unauthorized activities [began] on September 30, 2023, and ended on the morning of October 3, 2023, with the execution of the Ransomware (cf. Incident Response Report (IR) - v.1.1 attached to the note of June 19, 2024, pp. 8 - 9).

Only "on October 3, 2023, following the receipt of several reports from users of the Order stating that they were unable to access the network," did the Order realize the encryption of some servers and the deletion of backup data, initially believing that it was due to a technical issue. Subsequently, only "following an in-depth analysis conducted by the System Administrator (ADS) concluded on October 10, 2023, was it possible for the Controller to understand that the Incident represented a personal data breach under the Regulation (although it still did not have actual knowledge of the seriousness of the breach)" (Incident Response Report (IR) - v.1.1 attached to the note of June 19, 2024, pp. 8).

The Order had, therefore, not adopted any adequate measures to promptly detect personal data breaches based on anomalous behaviors resulting from access to the corporate network (such as, for example, the timing and frequency of accesses, typically nocturnal, their origin from IP addresses in foreign countries) and from operations carried out with domain accounts with or without administrative privileges (such as, for example, the deactivation of security measures or the termination of processes and services), also due to the fact that "to ensure constant monitoring of the alerts detected, the Order should also have qualified personnel in sufficient numbers to carry out this activity, even on weekends and at night" (note of November 15, 2024, cited).

Regarding the defenses presented by the Order following the administrative violation contestation, it should be noted that, as recently reiterated by the Authority (see provisions of July 17, 2024, no. 444, web document no. 10057610), the fact that the Order had "adopted its security measures in line with the provisions of the AgID Circular, conforming to the standard level," does not exempt, in general, the data controller from the obligation to carry out a concrete assessment of the appropriateness of the measures adopted to ensure the security of the processing, taking into account the context in which it operates. In particular, the adoption of the measures indicated in the aforementioned guidelines – which constitute, moreover, the "minimum security measures for the Italian public administration, keeping in mind the enormous differences in size, mandate, types of information managed, exposure to risk, and other characteristics of the over twenty thousand public administrations" – does not guarantee, by itself, compliance with security obligations. The aforementioned guidelines aim, in fact, to "indicate to public administrations the minimum measures for ICT security that must be adopted in order to counter the most common and frequent threats to which their information systems are subject," starting from "the set of controls known as SANS 20 [...] in version 6.0 of October 2015," and "ensure the minimum level of protection in most situations [...] keeping in mind the enormous differences in size, mandate,

****Types of Information Managed, Exposure to Risk, and Other Characteristics of the Over Twenty Thousand Public Administrations****

It is recommended that "each administration [...] identify [within its own] structure any potential subsets, technical and/or organizational, characterized by homogeneity of requirements and security objectives, within which [...] to uniformly apply the appropriate measures to achieve those objectives." Specifically, the Guidelines, having been issued based on the state of the art, technical knowledge, and cyber threats present in 2015, could not take into account the worsening of cyber risk in recent years, also due to the spread and adoption, during the COVID-19 pandemic, of technological methods and tools to

enable the conduct of activities (both work-related and otherwise) remotely. This change in scenario, given the significant increase in attacks by cybercriminals, would have required a renewed assessment that weighed the new and much more serious risks associated with processing concerning the rights and freedoms of the data subjects in relation to the adequacy of the measures adopted. The aforementioned assessment, which could not be crystallized and, therefore, concluded at the moment when the processing was designed, should have been periodically carried out over time, also in light of technological development; this was also to foster awareness regarding the necessity to mitigate risks arising from breaches of personal data. Therefore, the asserted compliance with the measures indicated in the aforementioned Agid Guidelines does not exhaust the obligation of the data controller to adopt adequate measures based on its own risk assessment. In fact, the Regulation, in compliance with the principle of accountability, assigns to the controller the task of identifying and adopting appropriate technical and organizational measures to ensure a level of security adequate to the risks presented by the processing, which, in this case, were particularly high due to the nature of the data processed, the large number of data subjects, including vulnerable individuals, as well as, in the event of a breach, the possible negative consequences for the data subjects in case of compromise of data confidentiality.

Furthermore, the defensive argument presented by the Order, based on the fact that the cyber attack in question was particularly sophisticated (data exfiltration in a progressive manner during nighttime and on holidays, without ever exceeding the average traffic threshold), cannot be accepted. Any real-time alert mechanisms for the timely identification of potential anomalies would have been ineffective in any case. Such automatic mechanisms, if appropriately configured and monitored, indeed allow for the detection of events that, precisely due to the particular precautions employed by the attackers, may escape human oversight, highlighting certain events (e.g., traffic during nighttime or on holidays, on days when no scheduled maintenance interventions are planned) even if not statistically significant (e.g., traffic in line with the average daily traffic threshold).

Nor can the circumstance that, as claimed by the Order, the adoption of the aforementioned automated alert systems would have entailed a high and disproportionate economic cost for the Order, being a public entity with limited organizational and financial resources, be deemed relevant. In this regard, it must be considered that Article 32 of the Regulation mentions "implementation costs" only among the factors that the data controller must take into account for the identification of appropriate technical and organizational measures to address the risks affecting the data subject to processing (cf. Article 24 of the Regulation). This factor "implies that the controller does not expend a disproportionate amount of resources if there are alternative, less costly but effective measures," while "the cost of implementation represents a factor to consider in realizing data protection from the design stage, and not a reason to refrain from doing so"; therefore, "the measures identified must [...] ensure that the processing activity planned by the controller does not involve processing of personal data in violation of the principles, regardless of the cost of such measures. Controllers must be able to manage overall costs to effectively implement all principles and, consequently, protect rights" (European Data Protection Board, "Guidelines 4/2019 on Article 25 - Data Protection by Design and by Default," adopted on October 20, 2020, paras. 24 and 25; cf. also ENISA, "Guidelines for SMEs on the Security of Personal Data Processing," December 2016, p. 12, where it is highlighted that "the reference [...] to implementation costs should not be interpreted as an excuse for inaction, but rather as an invitation to all stakeholders to simplify and reduce costs. In this sense, the approach to simplifying the notion of risk and adopting appropriate measures is fundamental for the correct implementation of this article," namely Article 32 of the Regulation).

It follows that, when the data controller decides to adopt less costly technical and organizational measures, these must still be equally effective in mitigating the risks affecting the data. As highlighted by the Authority, "implementation costs cannot be considered a factor that authorizes the data controller to lower the level of protection that the measures must ensure." adequate; if anything, they may constitute a factor to be taken into account when choosing between multiple solutions" (provision of July 17, 2024, no. 475, web document no. 10057648).

In this specific case, the Order cannot, therefore, invoke the limitation of its organizational and financial resources to justify the failure to adopt measures adequate to address the risks arising from the processing it has undertaken. On the other hand, following the violation of the personal data in question, the Order decided to install a “software tool for detecting threats to data security” (see note of January 19, 2024, p. 4), thus having the Entity able to bear the economic cost arising from the adoption of such a measure.

Data controllers are then required to consider the implementation costs along with the additional factors contemplated by Article 32 of the Regulation, namely the “state of the art,” the “nature, [...] object, [context and] purposes of the processing,” as well as the “risk of varying probability and severity for the rights and freedoms of natural persons” (cf. Article 25 of the Regulation).

Regarding the “state of the art,” it is “a dynamic concept that cannot be defined statically with respect to a specific moment, but should be subject to continuous evaluation in the context of technological advancements”; it “imposes an obligation on controllers, when determining the appropriate technical and organizational measures, to take into account the current advancements made by technology available on the market,” with the consequence that “controllers must be aware of technological advancements and remain continuously updated on the opportunities and risks for processing, in terms of data protection, arising from technologies and on how to implement and update the measures and guarantees that ensure effective implementation of the principles and rights of the data subjects, taking into account the evolution of the technological landscape” (“Guidelines 4/2019 on Article 25 - Data Protection by Design and by Default,” cited, paras. 18-20).

Considering, as mentioned above, the worsening of cyber risk in recent years, the adoption of the aforementioned automated alert systems must be considered, in the context of the processing in question, an adequate measure to the state of the art of technology and the current risk scenario. The “Guidelines 9/2022 on the notification of personal data breaches under the GDPR,” adopted by the European Data Protection Board on March 28, 2023 (hereinafter, the “Notification Guidelines”), indeed highlight that “the ability to identify, manage, and report a breach in a timely manner must be considered an essential aspect” of the technical and organizational measures that the controller and the processor must implement, pursuant to Article 32 of the Regulation, to ensure an adequate level of security of personal data (para. 41; cf. provision of July 17, 2024, no. 444, web document no. 10057610).

Regarding the “nature, [object,] context, and [purposes of the processing],” the Order should have duly taken into account the circumstance that, in the context of handling disciplinary proceedings, it may process personal data of vulnerable subjects (patients; minors), including data related to special categories of data or criminal convictions or offenses.

Paragraph 2 of Article 32 of the Regulation further specifies that, in assessing the appropriate level of security, particular attention must be paid to the risks presented by the processing, which arise particularly from destruction, loss, alteration, unauthorized disclosure, or unauthorized access, whether accidental or unlawful, to personal data. In this regard, the Order, for the purpose of identifying the necessary technical and organizational measures, should have considered the high risks for the data subjects that could arise from a potential disclosure of the aforementioned sensitive information, in terms of consequences on the economic and social relationships of the data subjects, particularly concerning the family, educational, or work environment, as also emerges from the reports and complaints received.

In light of the above considerations, it must be concluded that the failure of the Order to adopt the aforementioned technical and organizational measures constitutes a violation of Articles 5, para. 1, lett. f), and 32, para. 1, of the Regulation.

3.3 The failure to adopt adequate measures to ensure the security of processing systems.

In partial correction and clarification of the statements made during the investigation, the Order, supplementing the statements made during the hearing, stated that “access to the Order's IT systems

occurred due to a vulnerability of an RDP access point in the Order's infrastructure, although the attackers attempted to use credentials that were likely already in their possession (presumably through the dark web) or generated through a brute force attack," specifying that "the stolen credentials did not allow access to the Order's network (i.e., to the exposed RDP system)." Therefore, in its view, "even if the Order had adopted multi-factor authentication solutions, this would not have prevented the occurrence of the personal data breach."

Referring to what was highlighted in the previous para. 3.2 regarding the provisions of Articles 24 and 32 of the Regulation, particularly concerning the impossibility of invoking the costs of implementation. to justify the failure to adopt the necessary technical measures to protect the data, and considering that the adequacy of the measures implemented by the data controller must be evaluated in concrete terms, based on the various criteria provided by such articles and the data protection needs specifically related to the processing as well as the risks induced by it (see Court of Justice of the European Union, judgments C-687/21, MediaMarktSaturn, of January 25, 2024, para. 38, and C-340/21, Natsionalna agentsia za prihodite, paras. 30 to 32), it must be noted that the processing carried out by the Order in the context in question would have required the adoption of technical and organizational measures appropriate to the state of the art, in order to ensure the confidentiality of the personal data of the data subjects. This, as mentioned above, also in light of the purposes of the processing (also carried out within the framework of disciplinary proceedings), the high number of data subjects, the sensitive nature of the personal data processed (belonging to special categories and relating to criminal convictions and offenses), as well as the possible risks to the rights and freedoms of the data subjects, including vulnerable subjects (patients, minors, workers).

From the investigative activity, it emerged that the Order had not adopted adequate measures to ensure the security of the processing systems. In particular, the Order had not implemented a multi-factor authentication (MFA) system, which could have prevented unauthorized access to the systems even in the event of the compromise of authentication credentials. Only following the incident did the Order deem it necessary to "adopt a multi-factor authentication (MFA) system" (see notification of November 20, 2023, section H, point 2 and note of January 19, 2024, pp. 4 - 5).

It should also be noted that, although the Order stated that the credentials previously exfiltrated and present on the dark web were not used for the purpose of the attack in question, as they related to email, these credentials had not been adequately protected through encryption, nor could it be excluded that the attackers attempted to use the same credentials or other similar credentials to perpetrate the attack.

Lastly, from the statements made by the Order, it emerges that the server vector for the entry of the attack was equipped with an obsolete operating system (XX), whose vulnerabilities (RDP service exposed on default port) were exploited by the attacker to penetrate the Entity's infrastructure.

In light of the above considerations, the failure to adopt, at the time of the breach, adequate measures to ensure the security of the processing systems constitutes a violation of Articles 5, para. 1, lett. f), and 32, para. 1, of the Regulation.

4. Conclusions.

In light of the evaluations mentioned above, it is noted that the statements made by the data controller during the investigation – the veracity of which may be subject to accountability under Article 168 of the Code – although deserving of consideration, do not allow for overcoming the objections notified by the Office with the initiation of the procedure and are insufficient to allow for the closure of the present procedure, as none of the cases provided for by Article 11 of the Regulation of the Guarantor No. 1/2019 apply. Therefore, the preliminary evaluations of the Office are confirmed, and it is noted that the Order has multiple violations of Articles 5, para. 1, lett. f), and 32, para. 1, of the Regulation.

Considering that the violation of the aforementioned provisions occurred as a result of a single conduct (the same processing or related treatments), Article 83, para. 3, of the Regulation applies, according to which the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation. Given that, in this case, the most serious violation, relating to Article 5,

para. 1, lett. f), of the Regulation, is subject to the sanction provided for by Article 83, para. 5, of the Regulation, as recalled also by Article 166, para. 2, of the Code, the total amount of the sanction is to be quantified up to €20,000,000.

In this context, considering, in any case, that the conduct has exhausted its effects, since, as highlighted above, the Order has declared that it has adopted appropriate technical and organizational measures to prevent similar events in the future, the conditions for the adoption of further corrective measures under Article 58, para. 2, of the Regulation do not apply.

5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, para. 2, lett. i and 83 of the Regulation; Article 166, para. 7, of the Code).

The Guarantor, pursuant to Articles 58, para. 2, lett. i) and 83 of the Regulation as well as Article 166 of the Code, has the power to “impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] corrective measures [under this paragraph], or in lieu of such measures, depending on the circumstances of each individual case” and, in this context, “the College [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to Article 166, para. 7, of the Code” (Article 16, para. 1, of the Regulation of the Guarantor No. 1/2019).

In this regard, considering Article 83, para. 3, of the Regulation, in this case, the violation of the cited provisions is subject to the application of the administrative pecuniary sanction provided for by art. 83, par. 5, of the Regulation. The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into due account the elements provided for by art. 83, par. 2, of the Regulation.

Considering that:

- although the Order had not adopted real-time alert systems for the timely identification of any anomalies, it had at least implemented a firewall capable of detecting logs and RDP (Remote Desktop Protocol) connection attempts from the outside, including any unauthorized access attempts to the network, entrusting certain employees with the periodic monitoring of the same (cf. art. 83, par. 2, lett. a), of the Regulation);
- the exfiltration of data occurred progressively, generating traffic volumes that did not raise suspicions, during nighttime and on holidays, without ever exceeding the average traffic threshold, which evidently, for unknown reasons, was known to the attackers (cf. art. 83, par. 2, lett. a), of the Regulation);
- the violation did not compromise the availability and integrity of the personal data processed by the Order (cf. art. 83, par. 2, lett. a), of the Regulation);
- however, the violation involved a large number of personal data (“approximately 15,000 records”; “6.9GB”), including personal, contact, payment data, related to identity/recognition documents, belonging to special categories (i.e., data revealing ethnic origin, religious or philosophical beliefs, trade union membership, sexual life or sexual orientation, health status), related to criminal convictions and offenses, and covered by professional secrecy, with the consequence that the numerous data subjects to whom they refer (“3,000”, some of whom were involved in various ways in 159 disciplinary proceedings), including vulnerable subjects (minors, patients, workers), were exposed to potential risks of discrimination, identity theft, fraud, reputational risks, and other prejudices in the economic and social sphere (art. 83, par. 2, lett. a) and g), of the Regulation);
- considering the aforementioned risks to the rights and freedoms of the data subjects, as well as taking into account, on one hand, the current high level of cyber risk and, on the other hand, the state of the art in the field of cybersecurity, the conduct of the Order, which consists of having failed to adopt the aforementioned technical and organizational measures to safeguard the data, must be considered negligent, while it remains that the exfiltration and dissemination of the data are nonetheless attributable to a fraudulent behavior carried out by a criminal organization (“NoEscape”), through ransomware that has spread relatively recently (art. 83, par. 2, lett. b), of the Regulation);
- it is believed that, in this case, the level of severity of the violation committed by the data controller is

high (cf. European Data Protection Board, "Guidelines 4/2022 on the calculation of administrative pecuniary sanctions pursuant to the GDPR" of May 24, 2023, point 60).

That said, considering that the data controller, although equipped with a limited organizational structure (thirteen employees), is a public entity of regional relevance, which manages numerous members (25,499; source www.opl.it), it is believed that, for the purpose of quantifying the sanction, the following circumstances should be taken into account:

- the violation, which, due to the nature of the data involved and the categories of data subjects to whom they refer, is characterized by particular severity, occurred as a result of the failure to adopt adequate technical and organizational measures, for which the Order has a high degree of responsibility (art. 83, par. 2, lett. d), of the Regulation);
- the Order has notified the Authority of the personal data breach pursuant to art. 33 of the Regulation and has offered good cooperation with the Authority during the investigation, having, moreover, taken new technical and organizational measures aimed at strengthening the security of the processing and preventing any similar cyberattacks in the future (art. 83, par. 2, lett. f), of the Regulation);
- there are no previous relevant violations committed by the data controller (art. 83, par. 2, lett. e), of the Regulation).

In light of the aforementioned elements, assessed in their entirety, it is deemed appropriate to determine the amount of the pecuniary sanction at the sum of 30,000 euros (thirty thousand) for the multiple violation of arts. 5, par. 1, lett. f), and 32, par. 1, of the Regulation, as an administrative pecuniary sanction deemed, pursuant to art. 83, par. 1, of the Regulation, effective, proportionate, and dissuasive.

It is also believed that, pursuant to art. 166, paragraph 7, of the Code and art. 16, paragraph 1, of the Regulation of the Authority no. 1/2019, the publication of this section containing the injunction order on the Authority's website should proceed. This, as highlighted above, in consideration of the particularly sensitive context of processing in which the violation occurred, both due to the nature of the personal data subject to processing and the subjective characteristics of the data subjects, including vulnerable individuals.

Finally, it is noted that the conditions set forth in art. 17 of Regulation no. 1/2019 are met.

ALL OF THE ABOVE HAVING BEEN STATED, THE AUTHORITY declares, pursuant to art. 57, par. 1, lett. f), of the Regulation, that the processing has occurred in violation of Articles 5, paragraph 1, letter f), and 32, paragraph 1, of the Regulation, as detailed in the reasoning;

ORDERS

the Order of Psychologists of the Lombardy Region, represented by the legal representative pro tempore, with registered office at Corso Buenos Aires, 75 - 20124 Milan (MI), Tax Code 97134770151, to pay the sum of €30,000 (thirty thousand) as an administrative pecuniary sanction for the violations indicated in the reasoning. It is noted that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction;

COMMANDS

the aforementioned Order, in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €30,000 (thirty thousand) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law No. 689/1981;

DISPOSES

- pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Guarantor No. 1/2019, the publication of the injunction order on the Guarantor's website;
- pursuant to Article 154-bis, paragraph 3 of the Code and Article 37 of the Regulation of the Guarantor

No. 1/2019, the publication of this provision on the website of the Authority;

- pursuant to Article 17 of the Regulation of the Guarantor No. 1/2019, the annotation of the violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.

Pursuant to Articles 78 of the Regulation, 152 of the Code, and 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, April 29, 2025

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE ACTING SECRETARY GENERAL

Filippi